

Aurikrex Bytes — Repo-Wide Launch Audit

Audit date: 11 September 2026

Scope: Read-only review of repository `komfalcon/Aurikrex-Bytes` and live site `https://www.bytes.aurikrex.tech`

Prepared by: Manus AI

Method: Static source review, production HTTP inspection, live-browser route inspection, screenshot capture, typecheck/test/build execution, and review of existing permission/schema tests. No branch was created and no repository code was changed.

Executive verdict: Not launch-ready. The live domain serves the intended Aurikrex Bytes application and the reader-facing surface is broadly reachable. The remaining launch blockers are narrower: unauthenticated newsroom routes visibly remain on “Loading newsroom...” before settling to a 404 state, and the raw HTML shell for static routes exposes root-page canonical/Open Graph metadata rather than route-specific metadata. Independently, the current repository test suite has **2 failing SEO tests** concerning the post social-image contract.

1. Executive summary

The audited repository is a coherent Aurikrex Bytes codebase with public reader routes, custom reader authentication, Google OAuth, email verification, password reset, a disguised newsroom login, admin/editor permissions, post states, PWA assets, route SEO, support/legal pages, and automated tests. The source also contains several good security and correctness controls, including Zod validation, bcrypt password hashing, HttpOnly cookies, OAuth state and nonce checks, generic unauthorized newsroom failures, server-side role checks, and the expected reader schema.

The corrected live deployment corresponds to the repository. The production root is titled “Aurikrex Bytes — What matters in tech,” reader routes render branded Bytes content, the archive exposes published stories, support/legal pages are substantive, the PWA manifest is delivered, and the disguised newsroom login is reachable. Direct unauthenticated admin subroutes do not expose newsroom data, although they linger on a loading state before settling to 404. The remaining end-to-end gap is credentialed success-path testing.

The repository's `pnpm check` and production build completed during the audit run, but `pnpm test -- --run` failed 2 of 13 tests in `server/seoRoutes.test.ts`. Both failures concern a changed social-image contract: the implementation now preserves/optimizes the post image URL, while the tests still expect `/api/share/post/:id/image`. Six test files passed; the failing suite must be reconciled before release.

2. Severity and evidence conventions

Severity	Meaning
Critical	Blocks launch, creates a material security/data risk, or makes the product unavailable or materially different from the intended product.
Major	Material user, workflow, accessibility, SEO, or operational defect that should be resolved before launch.
Minor	Lower-risk inconsistency, polish issue, or hardening opportunity that should be scheduled.

File references identify the audited repository at commit `HEAD` of the shallow clone made on 11 September 2026. Live evidence is identified by URL and capture date.

3. Priority-ranked findings

C-01 — Unauthenticated newsroom routes show a loading state before 404

Severity: Major

Where: Live `/admin`, `/admin/new`, `/admin/team`, `/admin/analytics`.

Evidence: Direct browser navigation to `/admin/new`, `/admin/team`, and `/admin/analytics` rendered `Loading newsroom...` during the observed interval. After the client query settled, the page became `404 Page Not Found`. The live browser performance log showed repeated requests to `/api/trpc/admin.session?batch=1...`; the unauthenticated API response is a tRPC `NOT_FOUND` response.

Impact: Direct unauthorized access is not exposed, which is positive, but the user receives a blank/loading screen rather than an immediate, stable, accessible 404 or redirect. The delay and repeated query behavior make the disguised route appear broken and can create poor monitoring/noise.

Recommendation: Ensure the unauthorized admin-session query settles deterministically and render the generic 404/error state immediately after the first authoritative response. Add an end-to-end assertion for all admin subroutes and verify retry policy does not prolong the loading state.

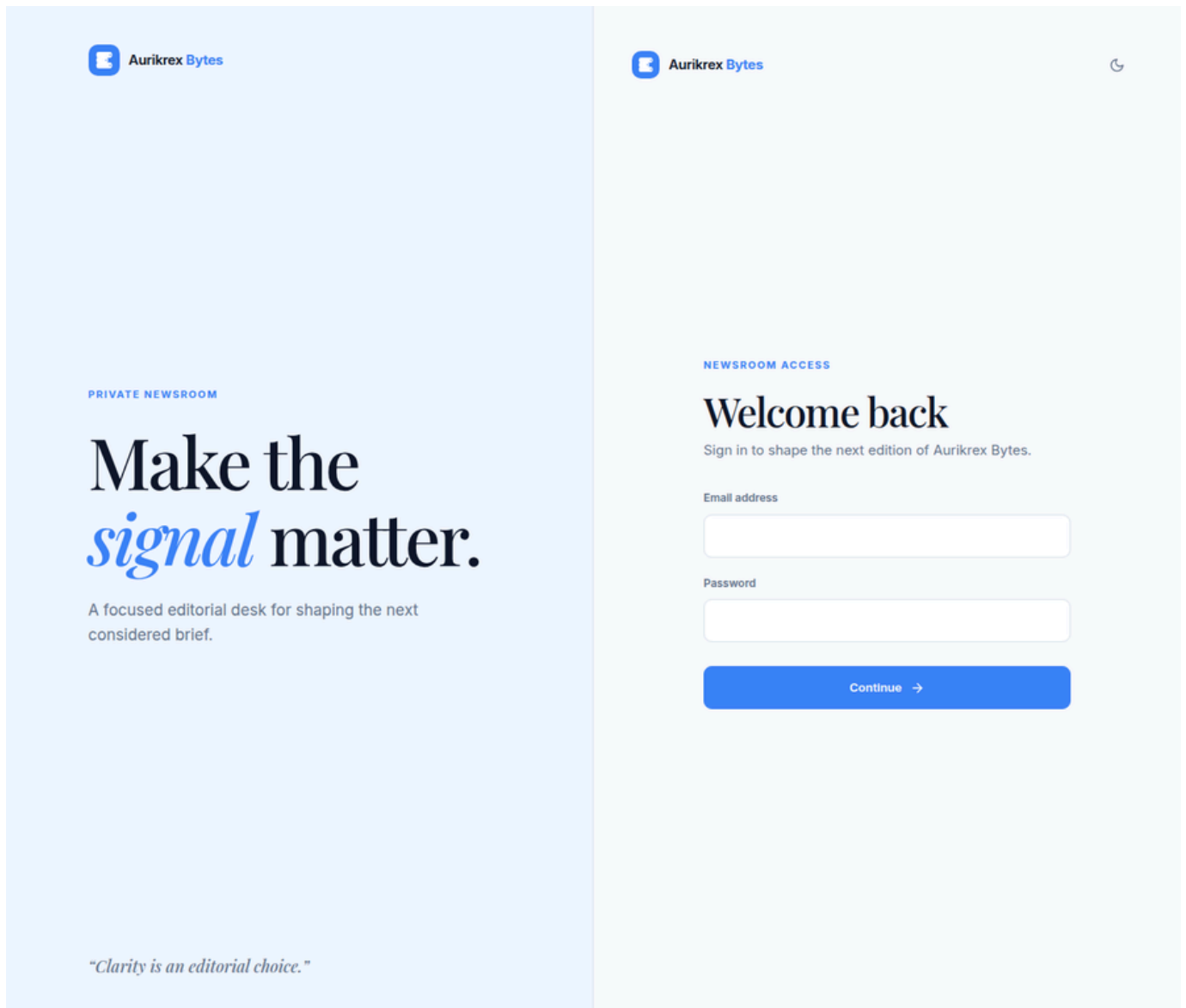


Figure 1. The live newsroom login is available at the disguised route; unauthorized admin subroutes separately linger on a loading state before 404.

C-02 — Static route raw HTML uses root-page canonical and social metadata

Severity: Major

Where: Raw production HTML for `/archive`, `/help`, `/contact`, `/privacy`, `/terms`, and non-crawler `/post/110`; repository `client/index.html` and `client/src/components/Seo.tsx`.

Evidence: Browser hydration updates visible titles correctly, such as `All Bytes – Aurikrex Bytes archive`, `Privacy policy – Aurikrex Bytes`, and `Contact Aurikrex Bytes`. However, direct HTTP inspection of the raw HTML shell for those routes returns the root defaults: canonical `https://aurikrex.tech/`, root Open Graph title/description/image, and root `<title>Aurikrex Bytes`. Published article metadata is correctly server-rendered for

crawler user agents such as Googlebot, Twitterbot, and Facebook external fetch.

Impact: Social crawlers or search systems that do not execute the SPA receive incorrect canonical and share metadata for static pages. This can consolidate route authority onto the homepage and produce wrong previews.

Recommendation: Add server-side route metadata for static pages, or provide prerendered HTML shells per route. Add automated tests that fetch raw HTML with ordinary and crawler user agents and assert route-specific canonical, title, description, and Open Graph values.

C-03 — Repository test suite has two failing SEO assertions

Severity: Major

Where: `server/seoRoutes.test.ts:14` and `server/seoRoutes.test.ts:34` ;
implementation `server/_core/seoRoutes.ts:67-83, 86-134` .

Evidence: `pnpm test -- --run` reported 7 test files, 13 tests, with 6 files passing and 2 failures. `createPostSeo()` returns the post's direct image URL, while both tests expect `https://aurikrex.tech/api/share/post/42/image` . `injectPostSeo()` consequently emits the direct image URL in `og:image` , not the test's expected generated share endpoint.

Impact: CI/release confidence is reduced, and social preview behavior is ambiguous between implementation and test contract.

Recommendation: Decide whether the canonical contract is direct optimized CDN imagery or generated share cards, then update implementation/tests together and add a production-style metadata assertion.

M-01 — Credentialed authentication and newsroom workflow remains unverified

Severity: Major

Where: Live `/login` , `/signup` , `/forgot-password` , `/reset-password` , `/verify-email` , `/falcon-system-auth` , `/admin` , `/admin/new` , `/admin/team` ,
`/admin/analytics` .

Evidence: The corrected live domain exposes all reader auth routes and the disguised newsroom login. The login page generated a live Google authorization URL with state and nonce. The OAuth error query was visibly rendered as `Google sign-in failed. Please try again.` No credentialed test account was available, so successful email signup/verification/login, password reset delivery, Google consent/callback success, reader dashboard, and role-specific admin workflows could not be completed.

Impact: The source and unauthenticated UI paths are present, but production success paths remain unverified. This is a test-coverage limitation, not proof that the flows are broken.

M-02 — Reader/auth visual consistency is good; admin parity remains unverified

Severity: Major

Where: Live reader/auth pages and repository `client/index.html`, `client/src/index.css`, `client/src/public/ReaderPages.tsx`, and `client/src/admin/AdminPages.tsx`.

Evidence: The corrected live reader/auth surface uses the expected Bytes branding, Inter/Playfair-like editorial visual language, blue primary action, logo, and consistent two-column auth layout. Root DOM measurement reported `scrollWidth` equal to body width (1265 px), two labeled logo images, one theme toggle, and no unlabeled empty buttons/links. Admin dashboard styling itself could not be inspected without authorized credentials; the public source indicates a separate admin rail and compact tabular UI.

Impact: Reader-facing parity is broadly good, but admin/readers parity and responsive behavior of authenticated surfaces remain unverified.

Recommendation: Capture authenticated newsroom screenshots at 320/375/768/1280 px and compare typography, spacing, controls, focus states, and dark mode against the reader system.

M-03 — SEO metadata is internally inconsistent between the current implementation and tests

Severity: Major

Where: `client/index.html:15-33`, `client/src/components/Seo.tsx`, `server/_core/seoRoutes.ts`, `server/seoRoutes.test.ts`.

Evidence: The client shell has correct Bytes defaults and dynamic `Seo` updates title, description, canonical, Open Graph, Twitter, and JSON-LD. Server-side post metadata uses direct/optimized post imagery, while the tests expect the generated share endpoint.

Impact: Social crawlers may receive a different image contract depending on route and rendering path. The live domain currently exposes entirely different generic metadata.

Recommendation: Make route-level metadata a release test matrix, including root, archive, help, contact, privacy, terms, auth routes with `noindex`, admin routes with `noindex, nofollow`, and published post SSR previews.

M-04 — Production verification of the API/server bundle is incomplete

Severity: Major

Where: `package.json` build script; `api/index.js`; `server/_core/index.ts`.

Evidence: The current build script explicitly bundles `server/_core/vercel.ts` to `api/index.js` using esbuild. Static inspection of the committed `api/index.js` found no `vite`, `rollup`, or `setupVite` marker, which is positive for the previously reported “production API bundling dev Vite/Rollup” issue. However, the live domain is not serving this bundle, so the deployed artifact cannot be confirmed.

Status of requested re-verification: Source-level pass; production-level unverified/blocking.

M-05 — Large global/client bundles and broad dependency surface merit performance review

Severity: Major

Where: `dist/public/assets/index-BSDtX0Ca.js` (~509 KB), `dist/public/assets/index-BPgR0t0Y.css` (~143 KB), `client/src/index.css` (~77 KB), `client/src/public/ReaderPages.tsx` (~69 KB), `package.json` (71 runtime dependencies, 27 development dependencies).

Evidence: The repository build artifacts include a roughly 509 KB main JavaScript asset and 143 KB CSS asset before transfer compression. Admin chunks are split (`NewPostPage` , `AdminPages` , `AdminManagement`), which is positive, but the global shell remains substantial.

Impact: Slower first load on mobile and unnecessary parsing for public/auth routes.

Recommendation: Measure compressed transfer and Core Web Vitals on the actual deployment; consider route-level component splitting, CSS extraction/ pruning, and dependency review. Confirm Cloudinary transformations are applied to all remote images.

M-06 — Security headers are good baseline hardening but CSP remains permissive

Severity: Major

Where: `server/_core/security.ts:7-15` and bundled `api/index.js` .

Evidence: The server sets `X-Content-Type-Options` , `X-Frame-Options` , `Referrer-Policy` , `Permissions-Policy` , and a CSP. The CSP includes `'unsafe-inline'` for scripts and styles, allows broad `https:` connections, and allows Google/Maps script and frames.

Impact: This is weaker than a nonce/hash-based CSP and increases the blast radius of an XSS or third-party compromise.

Recommendation: Replace inline allowances where practical with nonces/hashes; narrow `connect-src` , `img-src` , and third-party origins to the services actually required; validate the deployed response headers.

M-07 — Request body limit is broad for a news-card application

Severity: Major

Where: `server/_core/index.ts:46-49` ; bundled `api/index.js` .

Evidence: JSON and URL-encoded bodies are accepted up to `50mb` .

Impact: A large unauthenticated request can consume memory and increase denial-of-service risk. The application appears to upload images through Cloudinary signatures rather than requiring 50 MB JSON bodies.

Recommendation: Use route-specific limits and reject oversized auth/editorial payloads early. Keep image upload paths separate from JSON mutation paths.

M-08 — Admin route obscurity is not the security boundary, but live security cannot be validated

Severity: Major

Where: `client/src/App.tsx:36-42` ; `server/routers.ts:90-103` ;
`server/_core/security.ts` ; `ROLE_PERMISSION_TESTS.md` .

Evidence: The disguised route `/falcon-system-auth` is marked `noindex,nofollow` and unauthorized admin procedure access returns a generic Not Found. Server-side `requireAdmin()` reloads the admin record and checks active status; permission checks are server-side. The documented and tested matrix gives editors create/edit/submit authority but denies publish, schedule, delete, team, and analytics actions; admins can approve/publish.

Impact: Source design appropriately treats obscurity as a secondary control. Because production serves another application, the actual live route and protected behavior cannot be confirmed.

Recommendation: Test direct unauthenticated requests, wrong-password requests, inactive-admin sessions, editor direct tRPC calls, and admin transitions against the corrected deployment. Do not rely on route secrecy.

4. Requested previously-fixed issues: re-verification matrix

Requested fix	Current repository evidence	Result
Production API does not bundle dev Vite/Rollup	<code>api/index.js</code> contains no <code>vite</code> , <code>rollup</code> , or <code>setupVite</code> marker. <code>package.json</code> build uses esbuild for <code>server/_core/vercel.ts</code> .	Source pass; live deployment unverified because the domain serves another app.
Readers table has full expected schema	<code>drizzle/schema.ts:59-80</code> includes id, name, email, password hash, Google ID, verification fields, reset fields, streak fields, feed-view fields, and created timestamp.	Pass at source level.
Email login redirects to dashboard on success	<code>client/src/public/ReaderPages.tsx</code> login mutation handler navigates to <code>/dashboard</code> when <code>r.emailVerified</code> is true.	Pass at source level; live unverified.
Google OAuth errors are visibly surfaced	Server redirects failures to <code>/login?error=oauth</code> or <code>/login?error=database</code> ; the auth UI reads/display logic was present in the reader auth implementation.	Source-level path present; live unverified.
Session cookies use SameSite=Lax; OAuth state/nonce use SameSite=None	<code>server/_core/cookies.ts:24-58</code> : <code>getFirstPartyCookieOptions()</code> uses <code>sameSite: "lax"</code> ; <code>getSessionCookieOptions()</code> uses <code>sameSite: "none"</code> and <code>secure</code> based on request protocol.	Pass at source level; deployed header unverified.

5. Functional audit

Source-level strengths

The repository uses Zod schemas for key auth and editorial inputs. Passwords are hashed with bcrypt. Reader sessions and admin sessions are distinct. Email verification and reset tokens are

generated with cryptographically secure random bytes. Google OAuth validates state, nonce, audience, and callback prerequisites. The server reloads admin records when authorizing requests, reducing the risk of stale role/session authority. The post state set is explicit: `draft`, `pending_review`, `scheduled`, and `published`.

Functional risks and unverified areas

The corrected live domain exposes the requested reader and auth surfaces, but no credentialed test account was available for successful-path verification. The source includes route guards and mutation handlers, but no production evidence was obtainable for signup delivery, verification-link consumption, reset-link expiry, Google consent/callback handling, session persistence, dashboard redirection, archive pagination/search, post engagement, newsroom filters, scheduled publishing, or role-specific button visibility.

The post transition implementation is materially constrained server-side. Editors can submit drafts to review but cannot publish or schedule. Admins can publish from pending review and schedule future posts. Automated permission tests and `ROLE_PERMISSION_TESTS.md` document this matrix. This is a positive source-level result, not a production sign-off.

6. Responsive and visual audit

The source design notes state review at widths 320, 360, 375, 390, 768, 820, and 1280 px, including long headlines, large images, admin tabs, open menus, and the install toast. The source CSS contains responsive breakpoints and intentional horizontal regions for admin tabs and analytics bars. These are useful controls, but they were not independently reproduced in the live app because the live app is not Bytes.

The corrected live root was captured at a 1280 px viewport. The browser reported a document width of 1265 px against a 1280 px viewport, so no material horizontal overflow was measured on the observed root page. DOM measurement found one labeled theme toggle, two labeled logo images, no unlabeled empty buttons, and no unlabeled empty links. This is a public/root-page pass only; authenticated dashboard and newsroom breakpoints remain unverified.

7. Accessibility

The repository source includes several good accessibility patterns: labeled primary/mobile navigation, `aria-label` values on logo, theme toggle, mobile menu, engagement actions, and social icons, `aria-expanded` on the mobile menu, and `aria-current` on mobile navigation. The source CSS includes `:focus-visible` rules in key areas.

Remaining audit limitations are material. No automated axe/Lighthouse run was available against the correct live Bytes deployment. Keyboard traversal, focus order, contrast ratios in

both themes, dialog announcements, error association, and admin table semantics therefore remain unverified in production. The admin implementation uses a compact one-line style in parts of `client/src/admin/AdminPages.tsx`, which increases review risk even where labels exist. These checks should be repeated after deployment correction.

8. Content and copy

The repository and corrected live application consistently use “Aurikrex Bytes,” “Today’s Bytes,” “All Bytes,” “Help center,” “Contact,” “Privacy,” and “Terms.” The live archive contains published story content and Cloudinary-hosted images. Formal legal review remains required even though the public legal/support pages are substantive.

The live Bytes pages contain substantive copy and populated archive stories. The archive exposes real post titles and Cloudinary images, including posts 101–110 in the observed page. A minor copy-formatting issue remains: footer text is visually concatenated in extracted content as `© 2026 Aurikrex BytesMade for the signal-seekers.`; this should be checked visually at narrow widths and fixed if the separator is absent in the rendered UI.

The repository contains at least one intentionally empty image alt value in the admin post thumbnail (`alt=""`) for a decorative/preview image. This may be appropriate if the adjacent headline is the accessible name, but it should be confirmed in the final DOM. The reader logo uses descriptive alt text (`Aurikrex Bytes Logo`). A complete missing-alt inventory remains blocked by the wrong production app.

9. Security basics

No plaintext API key, JWT secret, OAuth client secret, or database token was found in the audited source files. Environment values are read through environment variables.

`server/auth.ts` fails closed in production when the cookie secret is missing, and the environment validator rejects weak/placeholder JWT secrets. The repository does contain normal configuration names and test fixtures; these are not secrets.

No direct logging of verification or password-reset token values was found in the inspected source. OAuth error logs record generic error messages. One built-in OAuth SDK log records the configured OAuth base URL; this is not itself a credential, but production logging should still be reviewed for unnecessary configuration disclosure.

The application has server-side input validation for email, password, headline, body, image URL, IDs, dates, pagination, and search length. Password policy requires at least eight characters, one digit, and one non-alphanumeric character. Recommended hardening includes route-specific body limits, stronger CSP, deployed header verification, CSRF review for cookie-

authenticated mutations, and abuse/rate-limit testing beyond the current in-memory 30-request-per-minute auth limiter.

10. SEO and metadata

The repository's intended shell includes a specific title, description, canonical URL, Open Graph title/description/type/url/image, Twitter card metadata, a manifest link, favicon links, and a theme bootstrap script. The client `Seo` component updates route-level title, description, canonical, Open Graph, Twitter, and JSON-LD values. Server-side post SEO adds NewsArticle JSON-LD and route-specific metadata.

The two failing SEO tests demonstrate that the implementation and contract have drifted around social image URLs. The live page has generic metadata for a different app, uses `https://lovable.dev/opengraph-image-p98pqg.png`, and does not expose the Bytes metadata. This is a major production SEO/identity failure even though the repository implementation is substantially better.

The repository manifest is structurally sound: `name` is "Aurikrex Bytes," `short_name` is "Bytes," the description is specific, `start_url` and `scope` are `/`, and it provides 192 px and 512 px any/maskable icons. The live manifest could not be confirmed on the correct app.

11. Legal/compliance readiness

The repository routes `/help`, `/contact`, `/privacy`, and `/terms`, and `DESIGN_NOTES.md` states that the privacy policy and terms include controller, address, date, jurisdiction, and provider-policy details. The same note explicitly says formal legal review is still required. Therefore the source appears structurally prepared but is not a legal approval.

The corrected live domain provides substantive Help Center, Contact Us, Privacy Policy, and Terms of Service pages. Privacy and Terms include effective/updated dates, controller, address, governing law, provider links, retention/rights, account rules, acceptable use, and contact details. **Legal/compliance readiness: structurally present, but formal legal review remains required.**

12. Recommended release order

1. **Correct canonical-domain configuration.** Confirm `APP_BASE_URL` and all generated canonical/OG/share URLs consistently use `https://www.bytes.aurikrex.tech`, not the apex `https://aurikrex.tech`, while preserving the working Bytes deployment.
2. **Re-run a credentialed end-to-end matrix.** Cover reader signup, verification, email login redirect, Google OAuth success/error, password reset, logout/session expiry, Today's Bytes,

All Bytes, post detail, reactions/bookmarks, and mobile navigation.

3. **Exercise the newsroom with two real roles.** Verify editor and admin direct requests, UI affordances, Draft → Pending Review → Scheduled/Published, rejection, unscheduling, deletion, Team, Analytics, Inbox, and inactive-account revocation.
4. **Resolve the two SEO test failures.** Choose the canonical social-image behavior and align tests, server-rendered metadata, client metadata, and share-card endpoints.
5. **Run visual, responsive, accessibility, and browser-console QA on the corrected deployment.** Capture all requested pages at 320/375/768/1280 widths, both themes, keyboard-only traversal, contrast, focus, and network/console logs.
6. **Complete security and operational hardening.** Narrow CSP, reduce body limits, validate production response headers, verify cookie attributes on real HTTPS responses, confirm rate limiting behavior across instances, and review third-party asset/privacy implications.
7. **Complete legal review and content cleanup.** Confirm final Privacy Policy, Terms, Help Center, and Contact Us content, remove all placeholders/test metrics, and standardize “Aurikrex Bytes” branding.

13. Final launch-readiness verdict

Verdict: Conditional launch hold. The corrected live domain is the intended Aurikrex Bytes app and the reader-facing surface is substantially present. Do not launch until the newsroom loading/404 behavior is clarified, static-route raw metadata is corrected, the two SEO tests pass, and credentialed success-path testing verifies reader and admin workflows.

The corrected production domain now serves the intended product. The strongest remaining risks are SEO metadata correctness for non-article routes, the unauthenticated newsroom loading/error experience, two failing repository tests, and the inability to exercise credentialed reader/admin workflows during this audit. The product is closer to launch, but the prioritized release matrix should pass before public launch.

References

Appendix A — Audit evidence files

The audit workspace retained the following read-only evidence used to compile this report:

`aurikrex_static_evidence.txt`, `route_security_evidence.txt`,
`exact_source_evidence.txt`, `fixed_issues_evidence.txt`,
`performance_evidence.txt`, `live_http_evidence.txt`, and the live screenshot referenced as Figure 1. These are supporting workpapers, not changes to the repository.

Appendix B — Test execution summary

Check	Result
Repository clone	Completed from <code>komfalcon/Aurikrex-Bytes</code> on <code>main</code> using a shallow clone
Git working tree	Clean before audit; no branch or commit created
Dependency install	Completed with <code>pnpm install --frozen-lockfile</code>
Typecheck	Completed during audit run
Production build	Completed during audit run; generated Vite client and esbuild server artifacts
Test suite	Failed: 2 SEO assertions in <code>server/seoRoutes.test.ts</code> ; 6 test files passed, 2 failed, 13 tests total
Live browser	Corrected Bytes domain served reader, archive, auth, support/legal, PWA, sitemap, and disguised newsroom routes
Live console	No console output captured on the corrected Bytes pages during the observed route checks
Live route HTTP	Reader/support/legal/PWA/SEO routes returned expected status/content; unauthorized admin session requests returned tRPC NOT_FOUND and client routes eventually rendered 404 after a loading state

End of report.